GRC Portfolio Artifact

INFORMATION SECURITY POLICY & ISO 27001 GAP ASSESSMENT

Author: Alexander Dabbs

Fictional Company:	Ceraphin Energy Solutions (CES)
Industry / Domain:	Critical Infrastructure, Smart Grid Technology, and Cloud Services
Regulatory Drivers:	NERC CIP (Critical Infrastructure Protection), ISO/IEC 27001:2022 Framework
Core Assets:	Cloud-hosted SCADA telemetry endpoints, AI Predictive Energy Consumption Engines, Sensitive Operational Technology (OT) Cloud-Gateways

Section 1: Company Profile & Risk Context

Ceraphin Energy Solutions (CES) provides advanced cloud-native infrastructure automation and grid optimization services for next-generation utility operators. CES operates a distributed operational model leveraging hybrid-cloud microservices to ingest high-frequency telemetry from regional **Supervisory Control and Data Acquisition (SCADA)** networks.

To drive efficiency, CES utilizes an advanced, proprietary **Artificial Intelligence (AI) Consumption Engine** that models historical grid demand patterns, weather anomalies, and spot-pricing variables to forecast load optimization vectors. Because CES links cloud systems directly to critical physical environments, its operating profile is strictly governed by the North American Reliability Corporation Critical Infrastructure Protection (**NERC CIP**) framework alongside corporate commitment to **ISO/IEC 27001:2022**.

Section 2: Corporate Policy Snippet (Policy ID: CES-POL-SEC-2026-004)

The following policy excerpt mandates access control, network isolation, and technical boundary integrity for high-impact assets.

1. Scope and Authority

This policy holds governing authority under the direction of the **Chief Information Security Officer (CISO)** and the **Regulatory Compliance Committee**. The **Security Operations Center (SOC)** is directly responsible for the continuous monitoring and operational defense of all scoped perimeters and environments.

The mandates herein apply to all employees, third-party contractors, and vendors who access, manage, or support CES operations. This also extends to systems, cloud data fabrics, predictive AI environments, and logical interfaces communicating with or housing BES Cyber Systems (BCSs), SCADA metadata, or customer load-profile data.

2. Access Control & Interactive Sessions (NERC CIP-004 Alignment)

All **Interactive Remote Access (IRA)** and administrative interface access to the cloud SCADA gateway or predictive AI code repositories must utilize hardware-backed Multi-Factor Authentication (MFA).

Access must strictly enforce the **Principle of Least Privilege (PoLP)** and role-based segregation of duties. AI training engineers shall not possess direct logical access or state modification privileges in active production SCADA pipelines.

All interactive sessions must enforce automatic inactivity timeouts and be fully logged. Access rights shall be reviewed quarterly and revoked immediately upon change in employment status or role.

3. Perimeter Security & Network Segregation (NERC CIP-005 Alignment)

All operations environments, Electronic Security Perimeters (ESPs), and SCADA collection proxies must reside in isolated virtual networks completely segmented from corporate administrative environments and public testing tiers.

Direct ingress from the public internet to SCADA cloud brokers is prohibited. All inbound and outbound traffic must clear designated **Interactive Remote Access Management (IRAM)** bastions featuring stateful traffic inspection and strict egress filtering.

Network perimeters must be continuously monitored by the SOC for unauthorized logical connections and malicious communication patterns.

Section 3: ISO/IEC 27001:2022 Gap Assessment Matrix

This mini-gap assessment evaluates selected security controls against ISO/IEC 27001:2022 and considers relevant NERC CIP requirements where applicable. Findings are based on the evidence described in this fictional scenario and do not constitute a complete compliance audit or certification assessment.

Control Reference	ISO 27001:2022 Control Objective	Status	Findings & Remediation Strategy
A.5.15	Access Control	COMPLIANT	**Findings:** Role-Based Access Control (RBAC) is tightly mapped via AWS IAM Identity Center. Separation between AI Model Training groups and active live SCADA ingestion infrastructure verified via separate IAM boundaries. **Evidence:** IAM configuration manifests indicate separate permissions for AI model training and production SCADA environments. Based on the evidence provided, the control appears implemented. Operational effectiveness was not independently tested as part of this assessment.
A.5.17	Authentication Information	COMPLIANT	**Findings:** The described authentication controls are intended to support secure access management and align with the relevant NERC CIP access control objectives. Identity verification mandates FIPS 140-2 validated

			hardware MFA tokens for all active interactive remote sessions. **Evidence:** Okta identity rules enforce biometric-backed hardware keys for all accounts mapped to the cloud grid console.
A.8.20	Network Security	PARTIAL COMPLIANCE	**Findings:** While the live cloud SCADA pipelines operate within strict isolation matching NERC CIP-005 requirements, the public API layer servicing the AI predictive consumption engine shares an upstream transit gateway architecture with the corporate development cluster, creating an aggregate perimeter hazard. **Remediation Strategy:** Segregate the predictive AI API endpoint infrastructure entirely out of the standard transit routing tables. Implement independent AWS Transit Gateways featuring isolated network routine inspection via cloud firewalls.
A.8.23	Web Filtering	NON-COMPLIANT	**Findings:** AI workloads run automated continuous training protocols that frequently scrape energy optimization indices and public regulatory updates dynamically from multiple third-party web domains. Currently, these specialized container workloads run without outbound proxy content filtering, presenting a vector for possible command-and-control exploitation. **Remediation Strategy:** Deploy container-level web egress filters (such as forward proxies with URL categorization) restricted by explicit whitelist logic. Block all outbound internet access within training nodes except to pre-approved data providers.

A.5.24-A.5.26	Incident Response Preparedness	NON-COMPLIANT	**Findings:** Documented and approved incident response procedures specific to security incidents affecting its cloud-hosted SCADA gateways and AI energy prediction infrastructure were absent. No evidence of incident response exercises or testing was provided to demonstrate that responsible personnel understand their roles and can effectively coordinate incident containment, escalation, and recovery. **Remediation Strategy:** Develop and formally approve an incident response plan defining incident classification, escalation procedures, stakeholder responsibilities, communication measures, and recovery processes. The plan should address scenarios involving unauthorized access to SCADA gateways, compromised cloud credentials, and suspicious activity within AI workloads. Conduct a tabletop exercise simulating a security incident affecting the cloud SCADA environment. Document the results, identify procedural gaps, assign remediation owners, and update the incident response plan accordingly.

Note as this is a fictional company, all information within is theoretical and has no comparison or relation to real-world companies or findings.